

CYBER SECURITY TASK 1

VULNERABILITY ASSESSMENT REPORT

Read-Only / Passive Security Assessment

Target Website

harshavardhan300805.github.io/NexMinds-FS-Developer-Assessment/

Assessment Date

30 September 2026

Prepared By

A. Harsha Vardhan

Educational, read-only, non-destructive assessment

Future Interns • Cyber Security Internship Task

1. Executive Summary

This vulnerability assessment was conducted against a publicly accessible personal portfolio website hosted on GitHub Pages. The assessment focused on common security configuration weaknesses using read-only and passive techniques.

Testing used Nmap for basic service exposure analysis, OWASP ZAP for passive web security analysis, and Chrome Developer Tools for HTTP response-header inspection. No exploitation, brute-force activity, denial-of-service testing, authentication bypass, or destructive testing was performed.

The assessment produced nine ZAP observations: five classified by ZAP as Medium, two as Low, and two as Informational. No High-risk finding was identified through the testing performed. The main recommendations are to strengthen browser security headers, review cross-origin configuration, review external resource loading and caching behavior, and minimize unnecessary technology information in response headers.

2. Assessment Scope & Ethics

Target: <https://harshavardhan300805.github.io/NexMinds-FS-Developer-Assessment/>

In scope: public-facing pages, HTTP/HTTPS responses, security headers, basic service exposure, and passive vulnerability detection.

Out of scope: exploitation, login bypass, brute force, denial-of-service testing, destructive testing, and unauthorized access.

The assessment was performed using a read-only approach intended to identify security weaknesses without attempting to compromise or disrupt the website.

3. Methodology & Tools

Assessment workflow

1. Target Website → 2. Nmap service exposure analysis → 3. OWASP ZAP passive security analysis → 4. Chrome DevTools HTTP-header review → 5. Evidence collection → 6. Risk classification and remediation.

Nmap: Basic network/service exposure analysis.

OWASP ZAP: Passive web security analysis and alert generation.

Chrome DevTools: Inspection of HTTP response headers and browser-visible configuration.

4. Nmap Service Exposure Results

Command used: `nmap -sV harshavardhan300805.github.io`

Port	State	Service	Observation
80/tcp	Open	HTTP	GitHub.com hosting infrastructure identified.
443/tcp	Open	SSL/HTTPS	GitHub.com hosting infrastructure identified.
998 other TCP ports	Filtered	—	No response from the scanned ports.

Open HTTP and HTTPS ports are expected for a public website and were not treated as vulnerabilities by themselves. The hostname resolves to multiple GitHub Pages addresses; Nmap scanned one address during this run.

5. Risk Summary

Risk Level	Count	Meaning in this assessment
High	0	No high-risk finding identified.
Medium	5	Security-header/configuration observations flagged by ZAP.
Low	2	Lower-impact information/configuration observations.
Informational	2	Review/observation items, not evidence of a vulnerability by themselves.
Total	9	Total ZAP alert categories documented.

V-01 — Content Security Policy (CSP) Header Not Set

Risk: Medium

Description: The examined response did not include a Content-Security-Policy header. CSP provides an additional browser security layer that can restrict the sources from which web content may be loaded.

Potential Impact: Absence of CSP removes an additional defensive layer against certain content-injection and cross-site scripting scenarios.

Recommendation: Configure an appropriate Content-Security-Policy that permits only the scripts, styles, fonts, images, and other resources required by the website.

V-02 — Cross-Domain Misconfiguration

Risk: Medium

Description: The examined response included Access-Control-Allow-Origin: *, allowing cross-origin access from arbitrary origins for the affected resource.

Potential Impact: Broad cross-origin permissions can increase exposure if resources containing sensitive information are made accessible through the affected endpoint.

Recommendation: Restrict cross-origin access to trusted origins where CORS is actually required. Avoid wildcard origins for sensitive resources.

V-03 — Missing Anti-clickjacking Header

Risk: Medium

Description: The examined response did not provide an anti-clickjacking control such as X-Frame-Options or an appropriate CSP frame-ancestors directive.

Potential Impact: Without an appropriate framing restriction, a page may have increased exposure to clickjacking scenarios if it can be embedded by another site.

Recommendation: Configure an appropriate Content-Security-Policy frame-ancestors policy or X-Frame-Options control.

V-04 — Subresource Integrity Attribute Missing

Risk: Medium

Description: ZAP identified an externally loaded resource without a Subresource Integrity attribute.

Potential Impact: SRI can provide an additional browser-side mechanism for checking the integrity of externally loaded static resources.

Recommendation: Use SRI where practical for externally hosted static resources and verify compatibility with the resource provider.

V-05 — X-Content-Type-Options Header Missing

Risk: Medium

Description: The examined response did not include the X-Content-Type-Options header.

Potential Impact: Without this control, browsers may have more opportunity to MIME-sniff resources than intended by the application.

Recommendation: Where supported, configure X-Content-Type-Options: nosniff.

V-06 — Server Information Disclosure

Risk: Low

Description: ZAP identified information exposed through the Server HTTP response header.

Potential Impact: Technology information can assist reconnaissance by identifying the hosting or server environment.

Recommendation: Minimize unnecessary server or technology information in response headers where the hosting platform permits it.

V-07 — Strict-Transport-Security Configuration Observation

Risk: Low

Description: ZAP identified an HSTS issue for an examined response. HSTS helps browsers consistently use HTTPS.

Potential Impact: Inconsistent HSTS behavior can reduce the browser-enforced HTTPS protection available for affected responses.

Recommendation: Verify HSTS consistently across HTTPS responses and configure it appropriately where the hosting platform permits. HSTS was observed in at least one HTTPS response during testing, so this is treated as an observation for the examined request/resource rather than proof that HSTS is absent from the entire website.

V-08 — Re-examine Cache-Control Directives

Risk: Informational

Description: ZAP recommends reviewing caching behavior to ensure that resources are cached appropriately.

Potential Impact: Improper caching can become relevant if a site later handles private or sensitive information.

Recommendation: Review Cache-Control settings according to the type of content being served.

V-09 — Retrieved from Cache

Risk: Informational

Description: ZAP detected a response being served from a cache. This is an observation rather than evidence of a vulnerability.

Potential Impact: Caching behavior should be appropriate to the sensitivity of the content being served.

Recommendation: Review caching behavior if the website ever handles private or sensitive information.

6. Remediation Plan

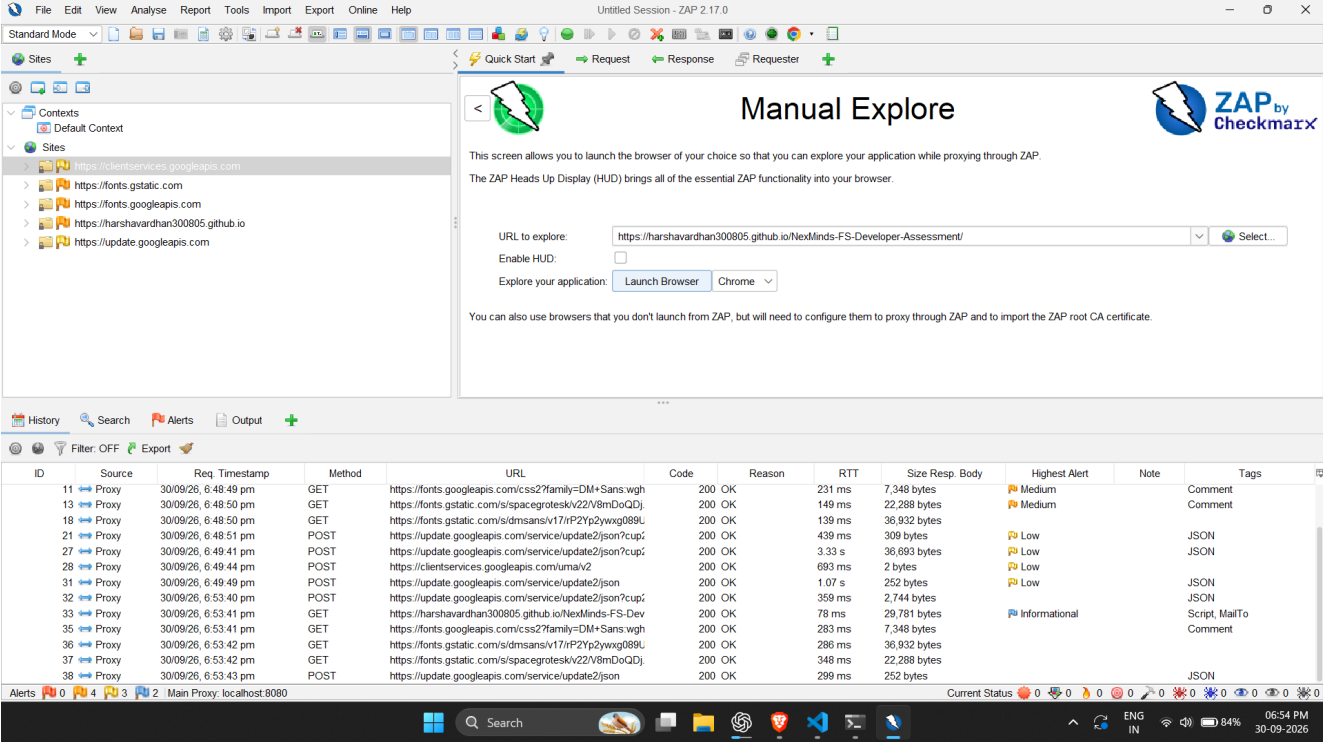
Priority	Recommended Action
1	Configure an appropriate Content Security Policy.
2	Review and restrict CORS configuration where cross-origin access is required.
3	Add anti-clickjacking protection using CSP frame-ancestors or an appropriate X-Frame-Options policy.
4	Add X-Content-Type-Options: nosniff where supported.
5	Review externally loaded resources and SRI applicability.
6	Review unnecessary server information disclosure.
7	Verify consistent HSTS behavior across HTTPS responses.
8	Review Cache-Control directives and caching behavior.

These recommendations are intended as practical configuration improvements. Their feasibility depends on the capabilities and constraints of GitHub Pages hosting and the resources used by the site.

7. Evidence Appendix

The following screenshots were supplied as assessment evidence. Each evidence item is placed with the corresponding observation so the report can be submitted with the supporting material.

Nmap / service exposure evidence



The screenshot displays the ZAP Manual Explore interface. The left sidebar shows a list of discovered sites, including:

- https://clientservices.googleapis.com
- https://fonts.gstatic.com
- https://fonts.googleapis.com
- https://harshavardhan300805.github.io
- https://update.googleapis.com

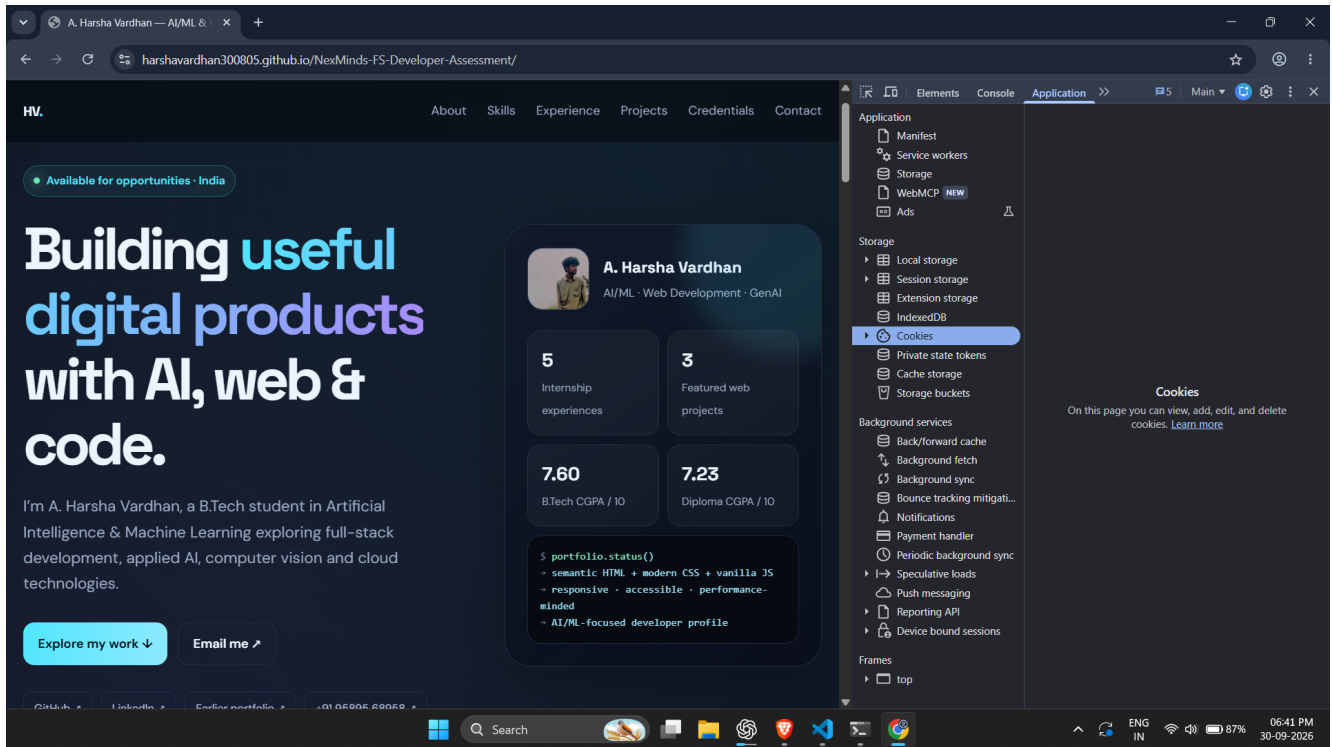
The main panel shows the 'Manual Explore' screen with the URL to explore set to <https://harshavardhan300805.github.io/NexMinds-FS-Developer-Assessment/>. The 'Enable HUD' checkbox is unchecked, and the 'Explore your application' dropdown is set to 'Launch Browser'.

Below the main panel, a table displays the Nmap service exposure results:

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
11	Proxy	30/09/26, 6:48:49 pm	GET	https://fonts.googleapis.com/css2?family=DM+Sans:wght@400;700&family=Roboto:ital,wght@0,400;0,700;1,400;1,700	200	OK	231 ms	7,348 bytes	Medium	Comment	
13	Proxy	30/09/26, 6:48:50 pm	GET	https://fonts.gstatic.com/s/spacegroteskv22/V8mDoQDj	200	OK	149 ms	22,288 bytes	Medium	Comment	
18	Proxy	30/09/26, 6:48:50 pm	GET	https://fonts.gstatic.com/s/dmsans/v17/rP2Yp2ywg089U	200	OK	139 ms	36,932 bytes	Low		
21	Proxy	30/09/26, 6:48:51 pm	POST	https://update.googleapis.com/service/update2?json?cup;	200	OK	439 ms	309 bytes	Low	JSON	
27	Proxy	30/09/26, 6:49:41 pm	POST	https://update.googleapis.com/service/update2?json?cup;	200	OK	3.33 s	36,693 bytes	Low	JSON	
28	Proxy	30/09/26, 6:49:44 pm	POST	https://clientservices.googleapis.com/uma/v2	200	OK	693 ms	2 bytes	Low		
31	Proxy	30/09/26, 6:49:49 pm	POST	https://update.googleapis.com/service/update2?json	200	OK	1.07 s	252 bytes	Low	JSON	
32	Proxy	30/09/26, 6:53:40 pm	POST	https://update.googleapis.com/service/update2?json?cup;	200	OK	359 ms	2,744 bytes	Low	JSON	
33	Proxy	30/09/26, 6:53:41 pm	GET	https://harshavardhan300805.github.io/NexMinds-FS-Dev	200	OK	78 ms	29,781 bytes	Informational	Script, MailTo	
35	Proxy	30/09/26, 6:53:41 pm	GET	https://fonts.googleapis.com/css2?family=DM+Sans:wght@400;700&family=Roboto:ital,wght@0,400;0,700;1,400;1,700	200	OK	283 ms	7,348 bytes		Comment	
36	Proxy	30/09/26, 6:53:42 pm	GET	https://fonts.gstatic.com/s/spacegroteskv22/V8mDoQDj	200	OK	286 ms	36,932 bytes			
37	Proxy	30/09/26, 6:53:42 pm	GET	https://fonts.gstatic.com/s/spacegroteskv22/V8mDoQDj	200	OK	348 ms	22,288 bytes			
38	Proxy	30/09/26, 6:53:43 pm	POST	https://update.googleapis.com/service/update2?json	200	OK	299 ms	252 bytes		JSON	

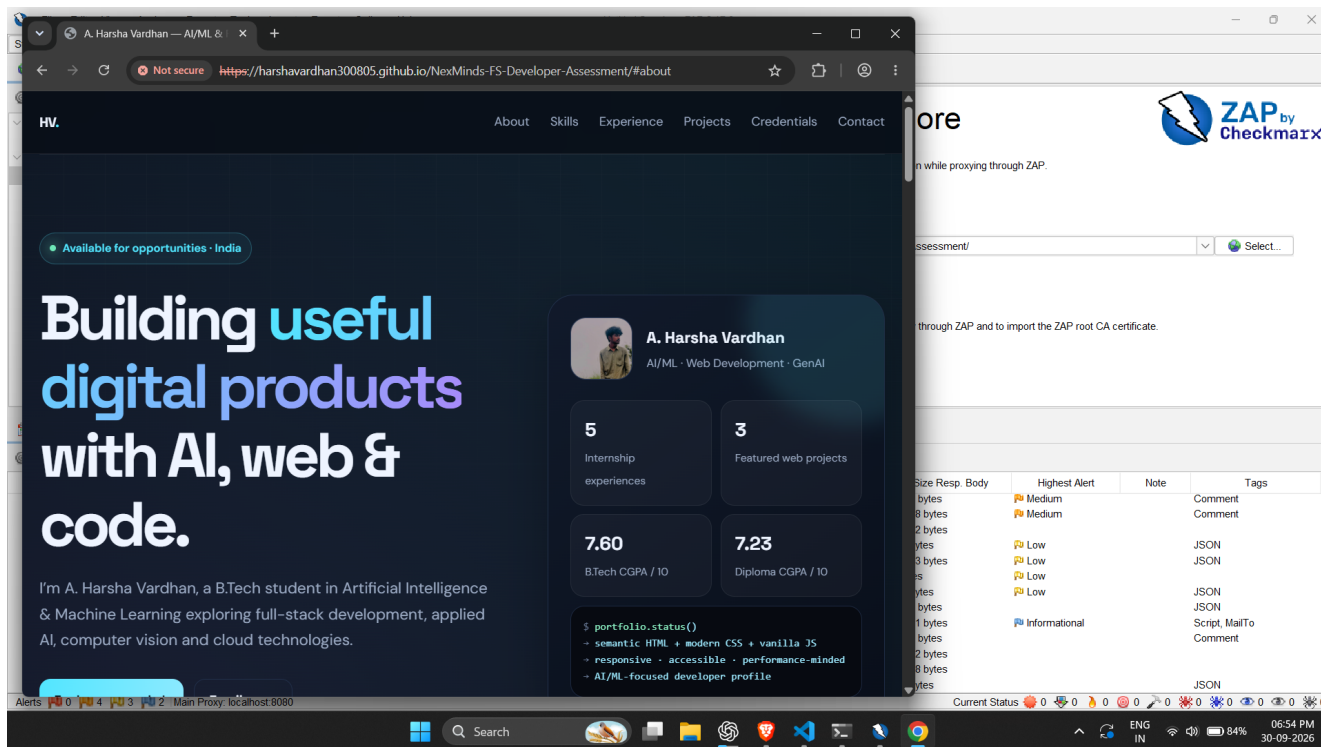
Nmap service exposure results used for Section 4.

Supporting Website Evidence — Screenshot 71



Browser view of the assessed portfolio website. This supports identification of the public-facing target and the assessment context.

Supporting Website Evidence — Screenshot 72



Additional browser view of the assessed portfolio website and its visible page content.

Supporting OWASP ZAP Evidence — Screenshot 73

The screenshot displays the OWASP ZAP (Zed Attack Proxy) interface in 'Manual Explore' mode. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is titled 'Manual Explore' and features a ZAP by Checkmarx logo. Below the title, a text box explains that this screen allows launching a browser to explore an application while proxying through ZAP, and that the ZAP Heads Up Display (HUD) brings all essential ZAP functionality into the browser. A form for 'URL to explore' is set to 'https://harshavardhan300805.github.io/NexMinds-FS-Developer-Assessment/'. The 'Enable HUD' checkbox is unchecked, and the 'Explore your application' dropdown is set to 'Launch Browser'. A note mentions that other browsers can be used but require configuration to proxy through ZAP and import the ZAP root CA certificate.

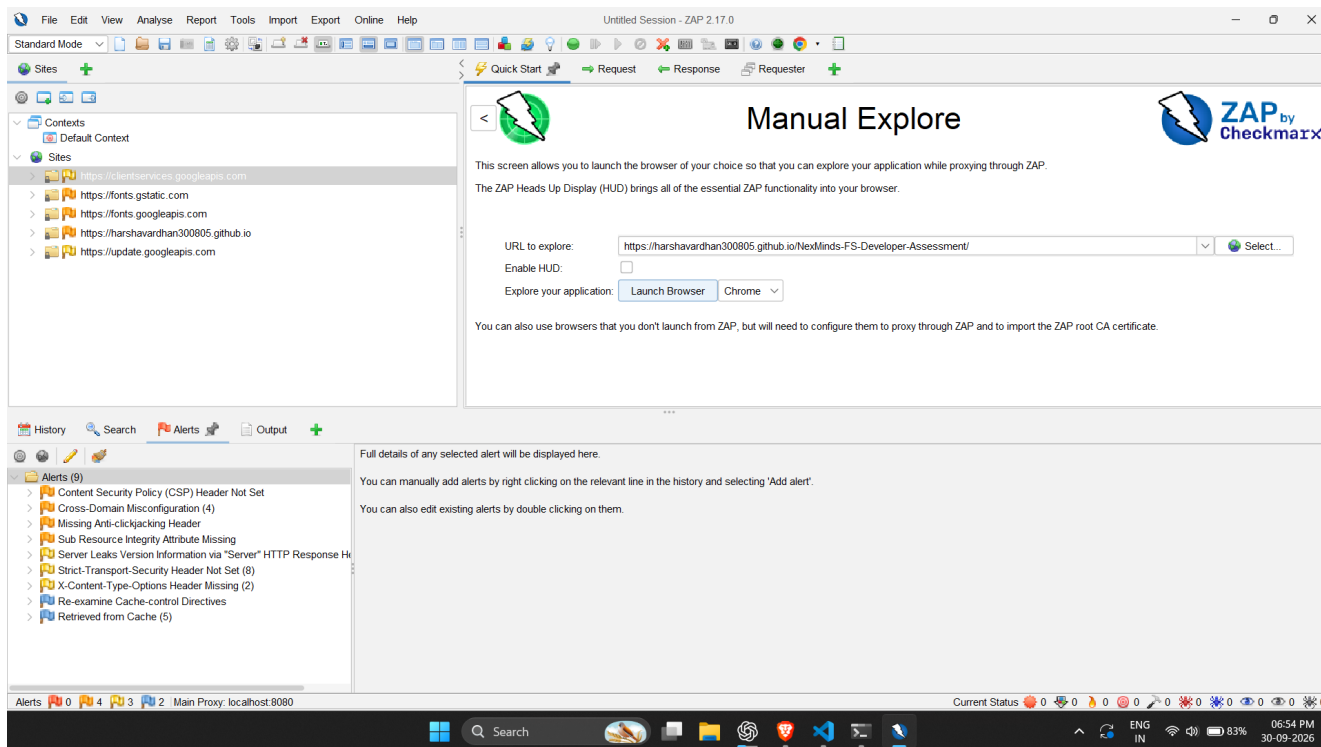
The bottom section shows a table of intercepted requests and responses. The table has columns for ID, Source, Req. Timestamp, Method, URL, Code, Reason, RTT, Size Resp. Body, Highest Alert, Note, and Tags. The data shows several requests to various Google APIs, all with a status of 200 OK.

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
11	Proxy	30/09/26, 6:48:49 pm	GET	https://fonts.googleapis.com/css?family=DM+Sans:wght	200	OK	231 ms	7,348 bytes	Medium	Comment	
13	Proxy	30/09/26, 6:48:50 pm	GET	https://fonts.gstatic.com/s/spacegroteskv22/V8mDoQDj	200	OK	149 ms	22,288 bytes	Medium	Comment	
18	Proxy	30/09/26, 6:48:50 pm	GET	https://fonts.gstatic.com/s/dmsans/v17/rF2Yp2ywg089U	200	OK	139 ms	36,932 bytes	Low		
21	Proxy	30/09/26, 6:48:51 pm	POST	https://update.googleapis.com/service/update2?json?cup;	200	OK	439 ms	308 bytes	Low	JSON	
27	Proxy	30/09/26, 6:49:41 pm	POST	https://update.googleapis.com/service/update2?json?cup;	200	OK	3.33 s	36,693 bytes	Low	JSON	
28	Proxy	30/09/26, 6:49:44 pm	POST	https://clientservices.googleapis.com/luma/v2	200	OK	693 ms	2 bytes	Low		
31	Proxy	30/09/26, 6:49:49 pm	POST	https://update.googleapis.com/service/update2?json	200	OK	1.07 s	252 bytes	Low	JSON	
32	Proxy	30/09/26, 6:53:40 pm	POST	https://update.googleapis.com/service/update2?json?cup;	200	OK	359 ms	2,744 bytes		JSON	
33	Proxy	30/09/26, 6:53:41 pm	GET	https://harshavardhan300805.github.io/NexMinds-FS-Dev	200	OK	78 ms	29,781 bytes	Informational	Script, MailTo	
35	Proxy	30/09/26, 6:53:41 pm	GET	https://fonts.googleapis.com/css?family=DM+Sans:wght	200	OK	283 ms	7,348 bytes		Comment	
36	Proxy	30/09/26, 6:53:42 pm	GET	https://fonts.gstatic.com/s/dmsans/v17/rF2Yp2ywg089U	200	OK	286 ms	36,932 bytes			
37	Proxy	30/09/26, 6:53:42 pm	GET	https://fonts.gstatic.com/s/spacegroteskv22/V8mDoQDj	200	OK	348 ms	22,288 bytes			
38	Proxy	30/09/26, 6:53:43 pm	POST	https://update.googleapis.com/service/update2?json	200	OK	299 ms	252 bytes		JSON	

The bottom status bar shows 'Alerts: 0', 'Main Proxy: localhost:8080', and 'Current Status: 0'. The system tray at the bottom right indicates the time as 06:54 PM on 30-09-2026, with 84% battery and network connectivity.

OWASP ZAP Manual Explore view showing the target being examined. This is supporting ZAP evidence, not an Nmap output.

Supporting OWASP ZAP Evidence — Screenshot 74



OWASP ZAP Manual Explore evidence showing the target/request exploration context.

Supporting OWASP ZAP Evidence — Screenshot 75

The screenshot displays the OWASP ZAP (Zed Attack Proxy) interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is titled 'Untitled Session - ZAP 2.17.0'. On the left, the 'Sites' pane shows a list of sites, including 'https://clientservices.googleapis.com', 'https://fonts.gstatic.com', 'https://fonts.googleapis.com', 'https://harshavardhan300805.github.io', and 'https://update.googleapis.com'. The central pane shows the 'Response' tab for a selected request. The response is an HTML document with a title 'A. Harsha Vardhan - AI/ML & Full-Stack Developer' and a description 'A. Harsha Vardhan - AI/ML and full-stack focused developer portfolio.' The bottom pane shows a list of requests with columns for ID, Source, Req. Timestamp, Method, URL, Code, Reason, RTT, Size Resp. Body, Highest Alert, Note, and Tags. The requests are sorted by RTT, showing various GET and POST requests to the same URLs as listed in the Sites pane. The bottom status bar shows 'Alerts: 0', 'Main Proxy: localhost:8080', and 'Current Status: 0'.

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
1	Proxy	30/09/26, 6:48:46 pm	POST	https://update.googleapis.com/service/update2?json?cup:	200	OK	493 ms	2,744 bytes	Low		JSON
5	Proxy	30/09/26, 6:48:47 pm	POST	https://update.googleapis.com/service/update2?json	200	OK	337 ms	252 bytes	Low		JSON
6	Proxy	30/09/26, 6:48:47 pm	GET	https://harshavardhan300805.github.io/NexMinds-FS-Dev	200	OK	839 ms	29,781 bytes	Medium		Script, MailTo
11	Proxy	30/09/26, 6:48:49 pm	GET	https://fonts.googleapis.com/css2?family=DM+Sans:wght@400;500;600;700&family=SpaceGrotesk:wght@500;600;700&display=swap	200	OK	231 ms	7,348 bytes	Medium		Comment
13	Proxy	30/09/26, 6:48:50 pm	GET	https://fonts.gstatic.com/s/spacegrotesk/v22/V8mDoQDj	200	OK	149 ms	22,288 bytes	Medium		Comment
18	Proxy	30/09/26, 6:48:50 pm	GET	https://fonts.gstatic.com/s/dmsans/v17/rP2Yp2ywg089U	200	OK	139 ms	36,932 bytes			
21	Proxy	30/09/26, 6:48:51 pm	POST	https://update.googleapis.com/service/update2?json?cup:	200	OK	439 ms	309 bytes	Low		JSON
27	Proxy	30/09/26, 6:49:41 pm	POST	https://update.googleapis.com/service/update2?json?cup:	200	OK	3.33 s	36,693 bytes	Low		JSON
28	Proxy	30/09/26, 6:49:44 pm	POST	https://clientservices.googleapis.com/luma/v2	200	OK	693 ms	2 bytes	Low		JSON
31	Proxy	30/09/26, 6:49:49 pm	POST	https://update.googleapis.com/service/update2?json	200	OK	1.07 s	252 bytes	Low		JSON
32	Proxy	30/09/26, 6:53:40 pm	POST	https://update.googleapis.com/service/update2?json?cup:	200	OK	359 ms	2,744 bytes			JSON
33	Proxy	30/09/26, 6:53:41 pm	GET	https://harshavardhan300805.github.io/NexMinds-FS-Dev	200	OK	78 ms	29,781 bytes	Informational		Script, MailTo
35	Proxy	30/09/26, 6:53:41 pm	GET	https://fonts.googleapis.com/css2?family=DM+Sans:wght@400;500;600;700&family=SpaceGrotesk:wght@500;600;700&display=swap	200	OK	283 ms	7,348 bytes			Comment

OWASP ZAP request/response exploration evidence. This is supporting tool evidence rather than a separate vulnerability finding.

V-01 — Content Security Policy (CSP) Header Not Set

The screenshot displays the OWASP ZAP 2.17.0 interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is divided into several panes. On the left, the 'Sites' pane shows a list of sites, including 'https://client-services.googleapis.com', 'https://fonts.gstatic.com', 'https://fonts.googleapis.com', 'https://harshavardhan300805.github.io', and 'https://update.googleapis.com'. The 'Alerts' pane on the left shows a list of alerts, with 'Content Security Policy (CSP) Header Not Set' selected. The main pane displays the details of this alert. The URL is 'https://harshavardhan300805.github.io/nextMinds-FS-Developer-Assessment/'. The risk is 'Medium', confidence is 'High', and the parameter is 'Attack'. The evidence shows a 'Server' HTTP response header. The CWE ID is 693, WASC ID is 15, and the source is 'Passive (10038 - Content Security Policy (CSP) Header Not Set)'. The alert reference is 10038-1. The input vector is 'Description: Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.' The solution is 'Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.' The reference is also provided.

OWASP ZAP evidence corresponding to V-01: Content Security Policy (CSP) Header Not Set.

V-02 — Cross-Domain Misconfiguration

The screenshot displays the OWASP ZAP 2.17.0 interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is titled 'Untitled Session - ZAP 2.17.0'. The left sidebar shows a tree view with 'Contexts' (Default Context) and 'Sites' (listing various domains like googleapis.com, gstatic.com, and github.io). The central pane shows a 'Response' tab with a 'Body Text' view, displaying an HTML document from GitHub. The bottom pane shows an 'Alerts' list with 9 alerts, including 'Content Security Policy (CSP) Header Not Set', 'Cross-Domain Misconfiguration (4)', 'Missing Anti-clickjacking Header', 'Sub Resource Integrity Attribute Missing', 'Server Leaks Version Information via "Server" HTTP Response Header', 'Strict-Transport-Security Header Not Set (8)', 'X-Content-Type-Options Header Missing (2)', 'Re-examine Cache-control Directives', and 'Retrieved from Cache (5)'. The 'Cross-Domain Misconfiguration (4)' alert is selected, showing details for the URL 'https://harshavardhan300805.github.io/NexMinds-FS-Developer-Assessment/'. The alert is categorized as 'Medium' risk and 'Medium' confidence. The 'Attack' parameter is 'Access-Control-Allow-Origin: *'. The 'Evidence' section shows the 'Access-Control-Allow-Origin: *' header. The 'Description' states: 'Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.' The 'Other Info' section explains that the CORS misconfiguration allows cross-domain read requests from arbitrary third-party domains, using unauthenticated APIs. The 'Solution' section advises ensuring that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance) and configuring the 'Access-Control-Allow-Origin' HTTP header to a more restrictive set of domains, or removing all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner. The 'Reference' section provides a link to a Fortify article: 'https://a.inr.at fortify.com/en/detail?category=HTML&subcategory=Security%20Permissive%20CORS%20Policy'.

OWASP ZAP evidence corresponding to V-02: Cross-Domain Misconfiguration.

V-03 — Missing Anti-clickjacking Header

The screenshot displays the OWASP ZAP 2.17.0 interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is titled 'Untitled Session - ZAP 2.17.0'. The left sidebar shows a tree view with 'Contexts' and 'Sites'. The 'Alerts' tab is selected, showing a list of alerts. The 'Missing Anti-clickjacking Header' alert is highlighted. The right pane shows the details of this alert, including the URL, risk, confidence, parameter, attack, evidence, source, alert reference, input vector, description, other info, solution, and reference.

Missing Anti-clickjacking Header

URL: <https://harshavardhan300805.github.io/NexMinds-FS-Developer-Assessment/>

Risk: Medium

Confidence: Medium

Parameter: x-frame-options

Attack:

Evidence:

CWE ID: 1021

WASC ID: 15

Source: Passive (10020 - Anti-clickjacking Header)

Alert Reference: 10020-1

Input Vector:

Description:

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Other Info:

Solution:

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's 'frame-ancestors' directive.

Reference:

OWASP ZAP evidence corresponding to V-03: Missing Anti-clickjacking Header.

V-04 — Subresource Integrity Attribute Missing

The screenshot displays the OWASP ZAP 2.17.0 interface. The top pane shows a list of sites, including <https://clientservices.googleapis.com>, <https://fonts.gstatic.com>, <https://fonts.googleapis.com>, <https://harshavardhan300805.github.io>, and <https://update.googleapis.com>. The middle pane shows the response of a request to <https://harshavardhan300805.github.io/NexMinds-FS-Developer-Assessment/>. The response is an HTML document with a title "A. Harsha Vardhan - AI/ML & Full-Stack Developer" and several links, including a preconnect link to <https://fonts.googleapis.com> and a link to <https://fonts.gstatic.com/css2?family=DM+Sans:wght@400;500;600;700&family=Space+Grotesk:wght@500;600;700&display=swap>. The bottom pane shows an alert titled "Sub Resource Integrity Attribute Missing". The alert details include the URL, risk level (Medium), confidence (High), and a description: "The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content." The solution provided is "Provide a valid integrity attribute to the tag." The reference is https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity.

OWASP ZAP evidence corresponding to V-04: Subresource Integrity Attribute Missing.

V-05 — X-Content-Type-Options Header Missing

The screenshot displays the OWASP ZAP interface. The top pane shows an HTTP response from a GitHub repository. The bottom pane shows a list of alerts, with 'X-Content-Type-Options Header Missing' selected. The alert details are as follows:

- URL:** <https://harshavardhan300805.github.io/NexMinds-FS-Developer-Assessment/>
- Risk:** Low
- Confidence:** Medium
- Parameter:** x-content-type-options
- Attack:**
- Evidence:**
 - CWE ID: 693
 - WASC ID: 15
- Source:** Passive (10021 - X-Content-Type-Options Header Missing)
- Input Vector:**
- Description:**

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
- Other Info:**

This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

At "High" threshold this scan rule will not alert on client or server error responses.
- Solution:**

Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
- Reference:**

[https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/in6f22941\(v=vs.85\)](https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/in6f22941(v=vs.85))

OWASP ZAP evidence corresponding to V-05: X-Content-Type-Options Header Missing.

V-06 — Server Information Disclosure

The screenshot displays the OWASP ZAP 2.17.0 interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is titled 'Untitled Session - ZAP 2.17.0'. On the left, the 'Sites' tree shows a list of sites, including 'https://clientservices.googleapis.com'. The 'Alerts' tab is active, showing a list of alerts. The selected alert is 'Server Leaks Version Information via "Server" HTTP Response Header Field'. The details pane on the right provides information about this alert:

- URL:** https://clientservices.googleapis.com/uma/v2
- Risk:** Low
- Confidence:** High
- Parameter:**
- Attack:**
- Evidence:** scaffolding on HTTPServer2
- CWE ID:** 497
- WASC ID:** 13
- Source:** Passive (10036 - HTTP Server Response Header)
- Alert Reference:** 10036-2
- Input Vector:**
- Description:** The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
- Other Info:**
- Solution:** Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
- Reference:**

The bottom status bar shows 'Alerts: 0 4 3 2' and 'Main Proxy: localhost:8080'. The system tray at the bottom right indicates the date and time as 07:07 PM on 30-09-2026.

OWASP ZAP evidence corresponding to V-06: Server Information Disclosure.

V-07 — Strict-Transport-Security Configuration Observation

The screenshot displays the OWASP ZAP (Zed Attack Proxy) interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is titled 'Untitled Session - ZAP 2.17.0'. The left sidebar shows a tree view with 'Contexts' and 'Sites'. The 'Sites' list includes 'https://clientservices.googleapis.com', 'https://fonts.gstatic.com', 'https://fonts.googleapis.com', 'https://harshavardhan300905.github.io', and 'https://update.googleapis.com'. The right pane shows the 'Response' tab for a request to 'https://update.googleapis.com/service/update2/json?cup2key=16Er7zNfG4SgQna8BGJKUxMl-90zzMUSLY-TKdF2BDDBA&cup2hreq=6dfd589a4b52875424fa9f59e9c86bc102d082dbb35ed5aecab09110'. The response is an HTTP 1.1 200 OK with a 'Content-Security-Policy' header. The bottom pane shows an 'Alerts' list with 9 alerts. The selected alert is 'Strict-Transport-Security Header Not Set (8)'. The alert details include: URL: https://update.googleapis.com/service/update2/json?cup2key=16Er7zNfG4SgQna8BGJKUxMl-90zzMUSLY-TKdF2BDDBA&cup2hreq=6dfd589a4b52875424fa9f59e9c86bc102d082dbb35ed5aecab09110, Risk: Low, Confidence: High, Parameter: Attack, Evidence: CWE ID: 319, WASC ID: 15, Source: Passive (10035 - Strict-Transport-Security Header), Alert Reference: 10035-1, Input Vector: Description: HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797. Other Info: Solution: Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.

OWASP ZAP evidence corresponding to V-07: Strict-Transport-Security configuration observation.

V-08 — Re-examine Cache-Control Directives

The screenshot displays the OWASP ZAP 2.17.0 interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is divided into several panes. On the left, the 'Alerts' pane shows a list of alerts, with 'Re-examine Cache-control Directives' selected. The central pane displays the details of this alert, including the URL, risk level, confidence, parameter, attack type, evidence, CWE ID, WASC ID, source, input vector, description, other info, solution, and reference. The right pane shows the HTTP response body, which includes headers like 'Access-Control-Allow-Origin: *', 'Strict-Transport-Security: max-age=31556952', 'ETag: "6ab89555-7455"', 'Expires: Wed, 30 Sep 2026 13:28:48 GMT', and 'Cache-Control: max-age=600'. The bottom status bar shows the current status, language (ENG IN), and the date and time (07:07 PM, 30-09-2026).

Re-examine Cache-control Directives

URL: <https://harshavardhan300805.github.io/NexMinds-FS-Developer-Assessment/>

Risk: Informational

Confidence: Low

Parameter: cache-control

Attack:

Evidence: max-age=600

CWE ID: 525

WASC ID: 13

Source: Passive (10015 - Re-examine Cache-control Directives)

Input Vector:

Description:

The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.

Other Info:

Solution:

For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".

Reference:

https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching

OWASP ZAP evidence corresponding to V-08: Re-examine Cache-Control Directives.

V-09 — Retrieved from Cache

The screenshot displays the OWASP ZAP 2.17.0 interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is divided into several panes. On the left, the 'Sites' pane shows a list of sites, including 'https://clientservices.googleapis.com', 'https://fonts.gstatic.com', 'https://fonts.googleapis.com', 'https://harshavardhan300805.github.io', and 'https://update.googleapis.com'. The 'Alerts' pane on the left shows a list of alerts, with 'Retrieved from Cache (5)' selected. The main pane displays the details of the selected alert, 'Retrieved from Cache'. The alert details include: URL: https://harshavardhan300805.github.io/NexMinds-FS-Developer-Assessment/, Risk: Informational, Confidence: Medium, Parameter: Age: 0, Evidence: CWE ID: 525, WASC ID: 10050-2, Source: Passive (10050 - Retrieved from Cache), Alert Reference: 10050-2, Input Vector: Description: The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as 'proxy' caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance. Other Info: The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use. Solution: Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user. Cache-Control: no-cache, no-store, must-revalidate, private. Reference: The top pane shows the 'Response' tab of a request, displaying the 'Header: Text' and 'Body: Text' sections. The 'Header: Text' section shows the following headers: x-proxy-cache: MISS, X-GitHub-Request-Id: A1AC:1F41A2:532DBA:55A5EB:6AB00C37, x-github-edge-region: centralindia, Accept-Ranges: bytes, Age: 0. The 'Body: Text' section shows the following HTML content: <!doctype html>, <html lang='en'>, <head>, <meta charset='utf-8'>, <meta name='viewport' content='width=device-width,initial-scale=1'>.

OWASP ZAP evidence corresponding to V-09: Retrieved from Cache.

8. Conclusion

A read-only vulnerability assessment was conducted against the publicly accessible portfolio website hosted on GitHub Pages. The assessment used Nmap, OWASP ZAP passive scanning, and browser-based HTTP header inspection.

The assessment identified several security-header and configuration observations, primarily involving browser security controls, cross-origin configuration, response-header information, and caching behavior. No high-risk finding was identified through the testing performed.

The recommended remediation actions focus on strengthening security headers, reviewing cross-origin and caching behavior, and minimizing unnecessary information exposure. Regular security reviews are recommended whenever the website code, dependencies, hosting configuration, or external resources change.

9. Assessment Declaration

Assessment Type: Read-Only Vulnerability Assessment

Target: Personal portfolio website hosted on GitHub Pages

Testing Approach: Passive / Non-destructive

Tools: Nmap, OWASP ZAP, Chrome DevTools

Assessment Date: 30 September 2026

Ethical Statement: This assessment was performed for educational and security-awareness purposes on a website controlled by the assessor. No exploitation, brute-force activity, denial-of-service testing, authentication bypass, or destructive actions were performed.

Prepared by

A. Harsha Vardhan